Proceso de auditoría y análisis de vulnerabilidades

Introducción:
El presente informe detalla el proceso de auditoría y análisis de vulnerabilidades realizado sobre la infraestructura tecnológica simulada de la empresa "Soporte Experto Educación Superior" (SEES). Considerando la designación de SEES como Operador de Importancia Vital (OIV) bajo la Ley Marco de Ciberseguridad (Ley 21.663), se llevó a cabo una evaluación práctica utilizando el escáner OpenVAS en un entorno Kali Linux para analizar un servidor vulnerable (Metasploitable). El objetivo de este documento es justificar los controles de seguridad aplicados desde una perspectiva ética y normativa, evidenciar el escaneo de la red y proponer acciones de mitigación concretas para las cinco vulnerabilidades más críticas detectadas, garantizando así la protección de los datos y la infraestructura de la organización.

Especificaciones del Software

Características	Máquina OpenVas(KaliLikux)	Maquina VUlnerable (Metasploitable)
Nombre del Host	Kali-Linux-2021-OK	Metasploitable3-ub1404
CPU	4 Procesadores	2 Procesadores
RAM	10730 MB	2048 MB
HDD	80.00 GB (SATA)	-

Características	Máquina OpenVas(KaliLikux)	Maquina VUlnerable (Metasploitable)
Sistema Operativo	Debian (64-bit)	Ubuntu 14.04
IP	192.168.56.131 (eth1)	192.168.56.103
Máscara de Subred	255.255.255.0	255.255.255.0
Gateway / DNS	0.0.0.0 (Red Local)	10.0.2.2

Definición y Justificación de Controles

1. Controles para proteger los datos (IE1.1.1):
   Cifrado de datos en reposo y en tránsito (AES-256 y TLS 1.3): Garantiza que la información

confidencial de las instituciones de educación superior sea ilegible en caso de una brecha o intercepción.

Control de Acceso Basado en Roles (RBAC): Limita el acceso a los datos únicamente al personal autorizado de Soporte Experto Educación Superior (SEES) según sus funciones específicas.

2. Controles para proteger la infraestructura tecnológica (IE1.1.2):
   Firewall de Próxima Generación (NGFW): Inspecciona el tráfico de red a nivel de aplicación para bloquear amenazas avanzadas antes de que ingresen a la red de SEES.

Sistema de Detección y Prevención de Intrusos (IDS/IPS): Monitorea continuamente la red en busca de comportamientos anómalos o firmas de ataques conocidos, bloqueándolos automáticamente.

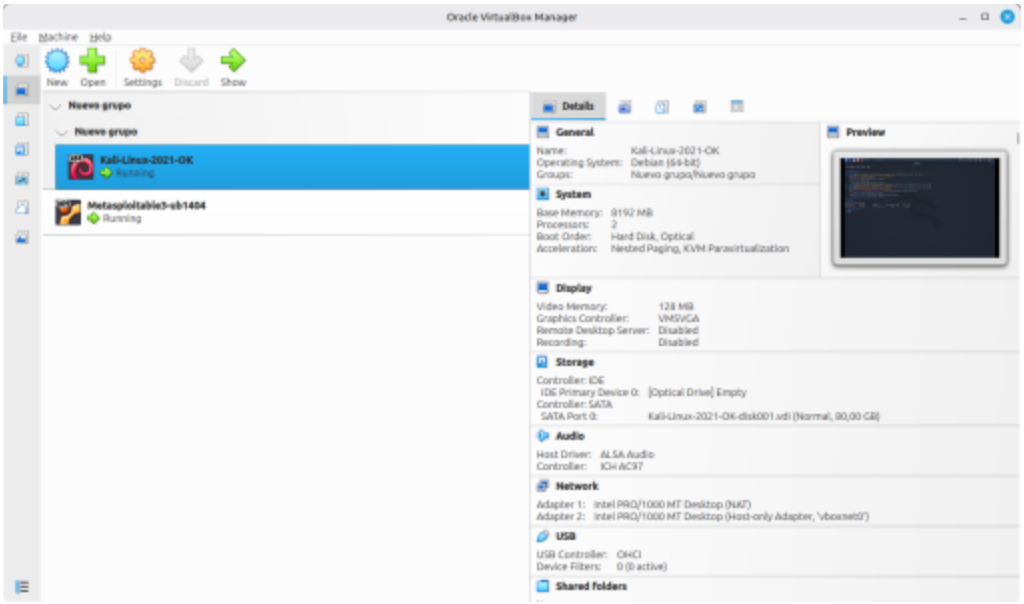
3. Justificación Ética y Normativa de los Controles Seleccionados (IE1.2.1 e IE1.2.2):
   Cifrado de Datos: Al implementar cifrado, SEES cumple con su deber como Operador de Importancia Vital (OIV) protegiendo la privacidad de los estudiantes y docentes, respetando leyes de protección de datos personales y evitando la exposición indebida de información sensible.

RBAC: Éticamente, asegura el principio de "mínimo privilegio". Esto evita que empleados sin autorización accedan a datos privados, protegiendo los derechos de los usuarios finales y reduciendo el riesgo de abuso de información interna.

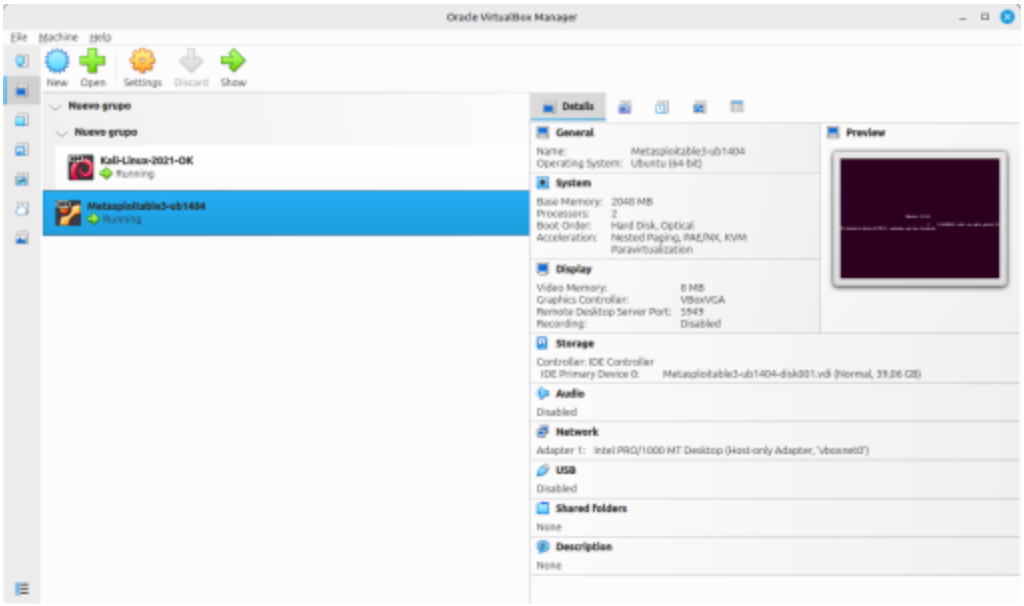
Monitoreo mediante IDS/IPS: Se implementa de forma transparente y enfocada únicamente en el tráfico de red de la infraestructura, no en el contenido de las comunicaciones personales.

Esto equilibra la necesidad de seguridad exigida por la normativa vigente con el derecho a la privacidad de los usuarios que utilizan la red.

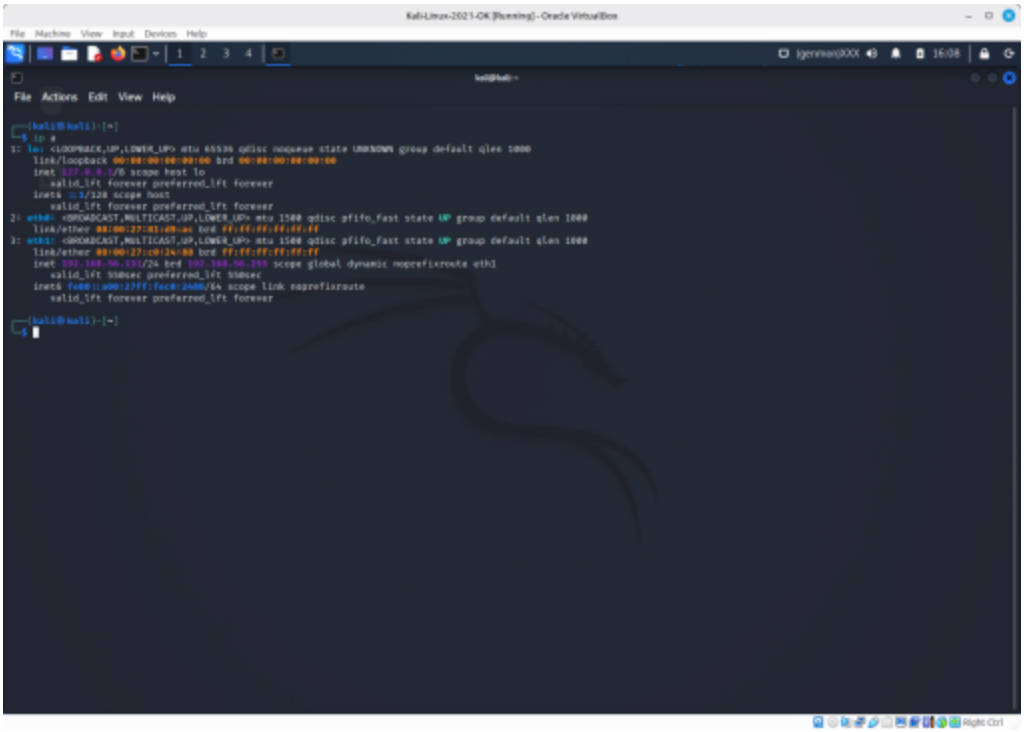
Máquinas utilizadas (Kali-Linux)

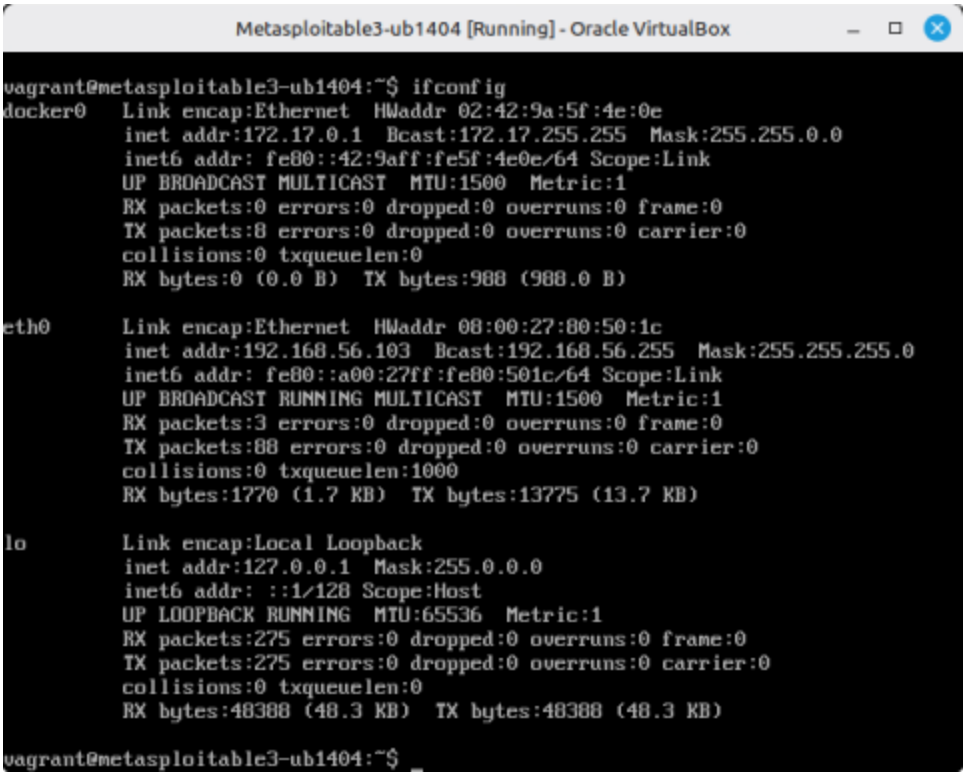


Segunda máquina utilizada (Metasploitable)

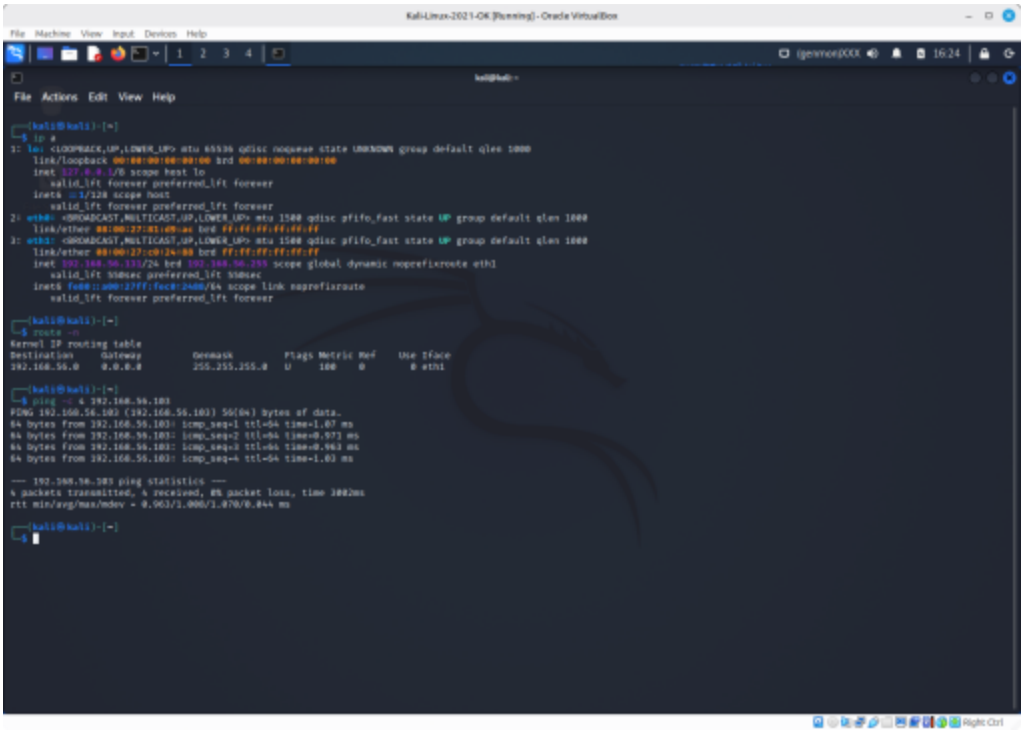


Obtener la ip de ambas máquinas

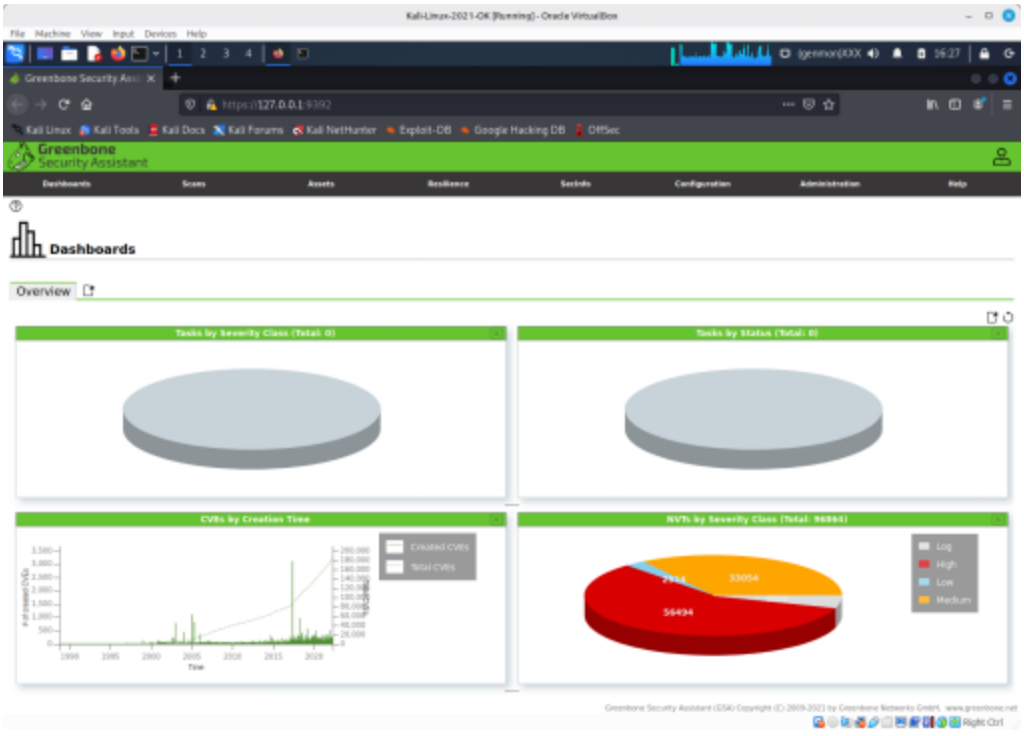




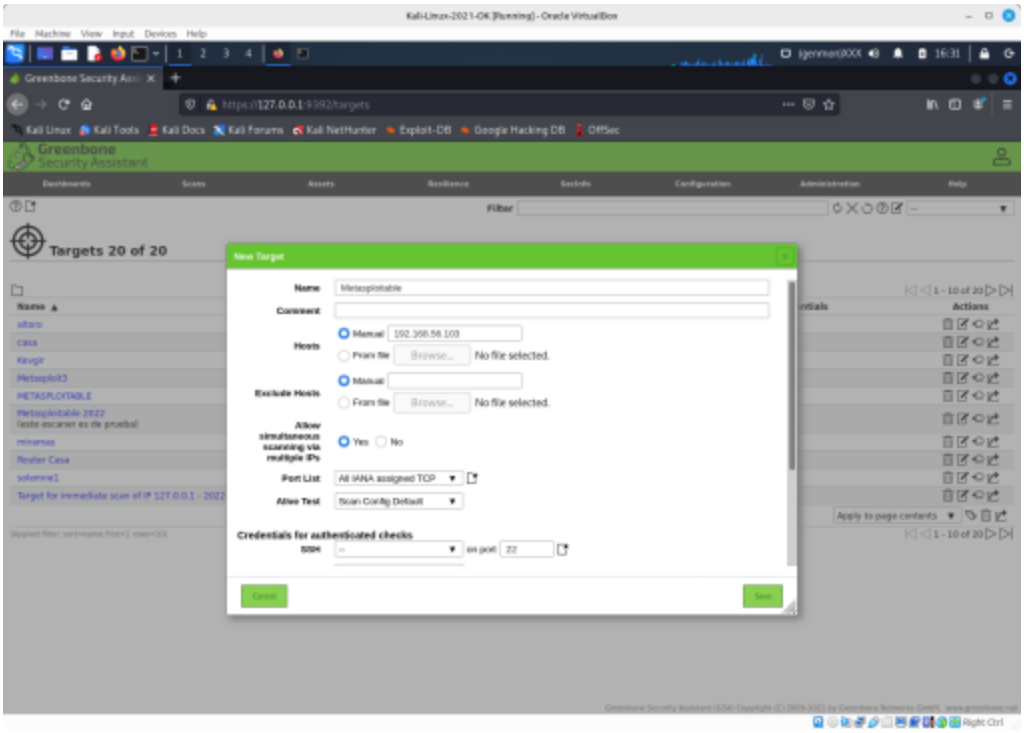
Prueba de conectividad

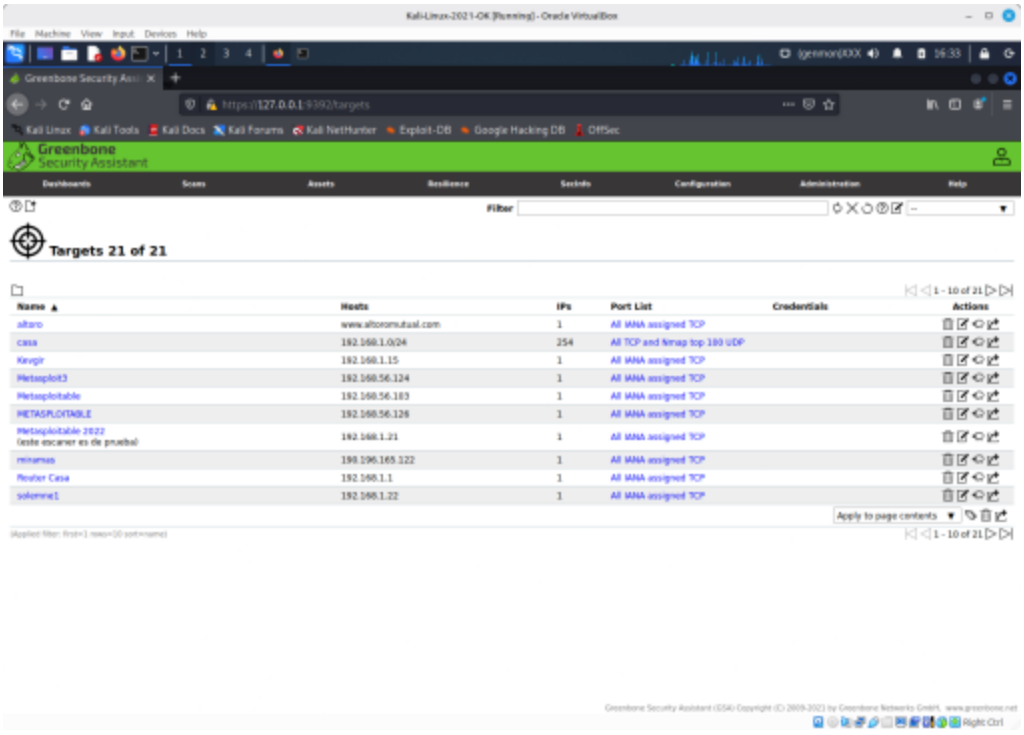


Análisis de vulnerabilidades con OpenVAS

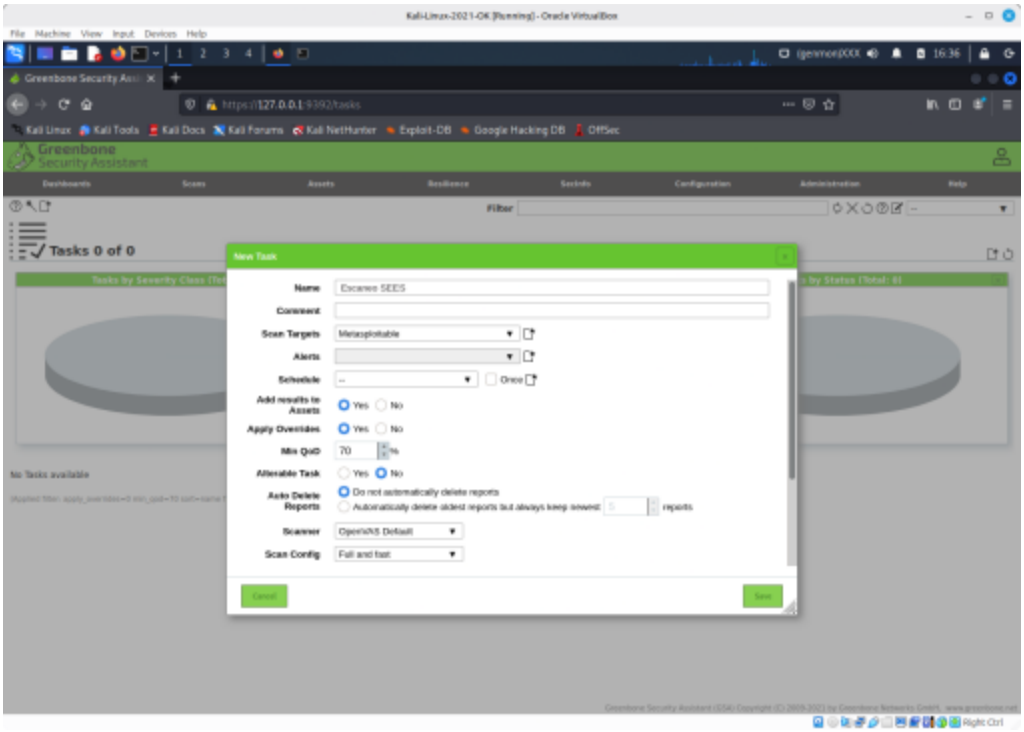


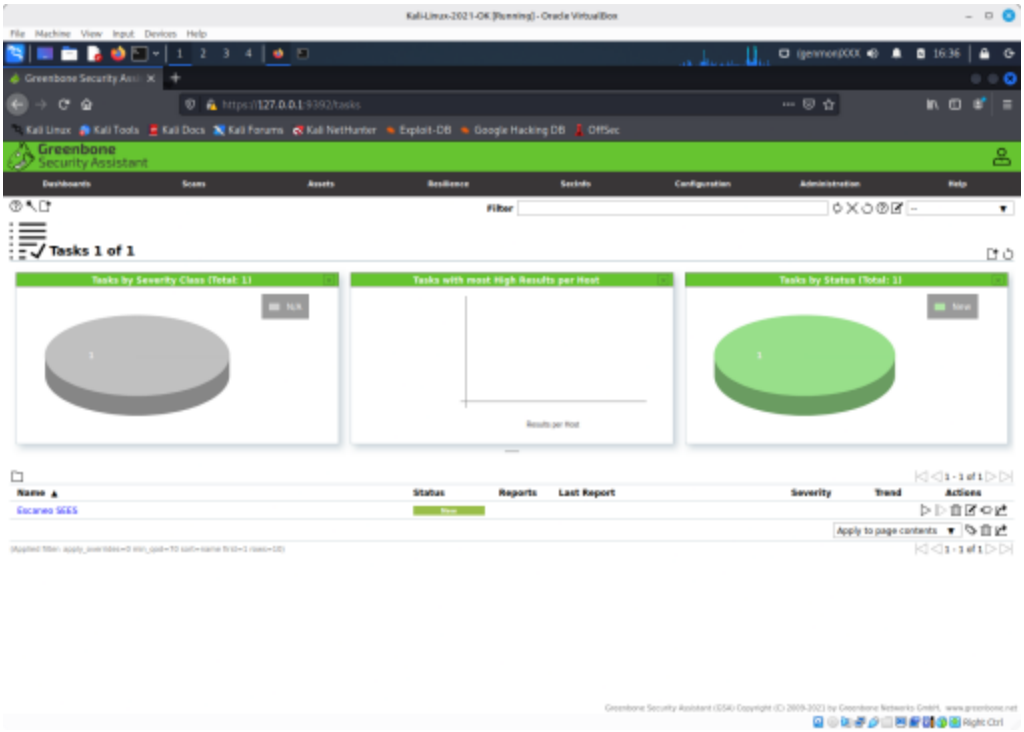
Crear el Objetivo (Target)



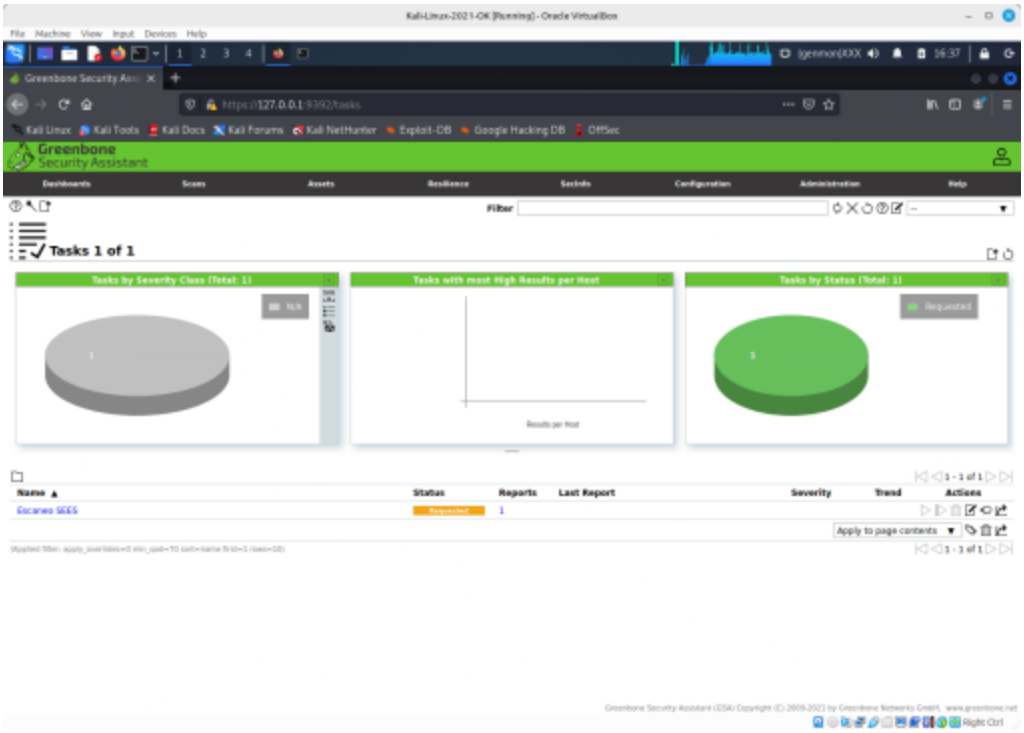


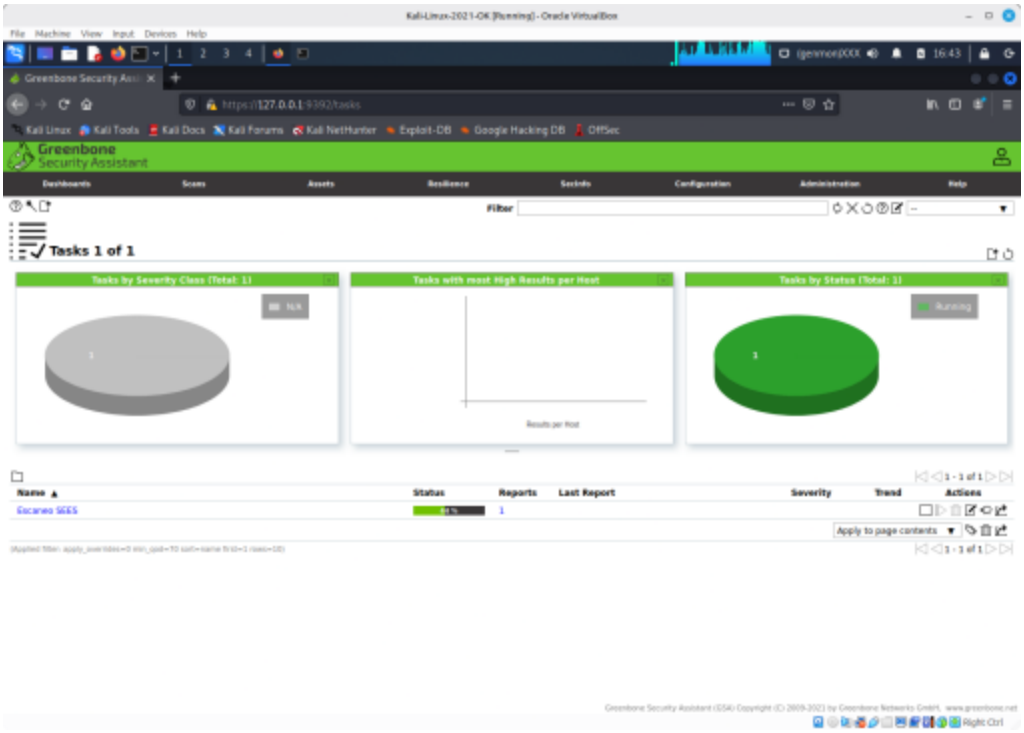
Tarea de escaneo



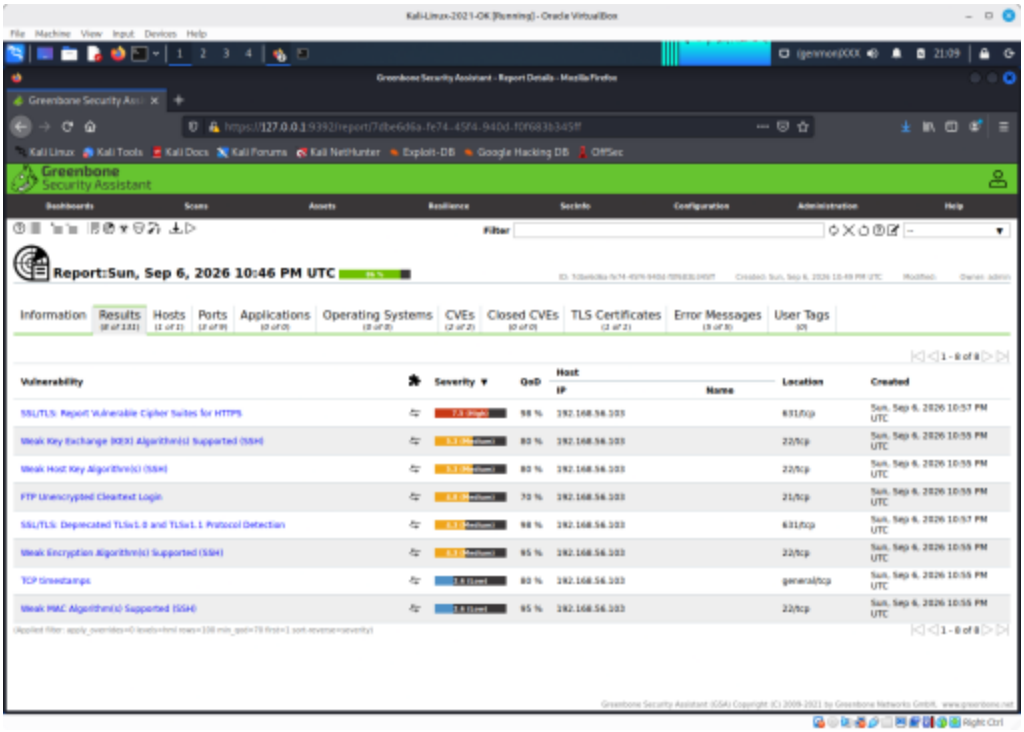


Iniciar Análisis





Resultados



Vulnerabilidad 1:
Nombre: SSL/TLS: Report Vulnerable Cipher Suites for HTTPS
ID de CVE: CVE-2016-2183, CVE-2016-6329, CVE-2020-12872
Descripción: El servicio acepta suites de cifrado débiles a través de HTTPS (TLSv1.0, 1.1 y 1.2). Específicamente, el cifrado de bloques de 64 bits (3DES) es vulnerable al ataque SWEET32, lo que podría permitir a un atacante descifrar el tráfico de red interceptado Fecha de publicación: Año 2016
CVSS Score: (7.5)
Acciones para corregir: Modificar la configuración del servicio (servidor web) para que deje de aceptar las suites de cifrado vulnerables (deshabilitar 3DES) y forzar el uso de cifrados modernos

Vulnerabilidad 2:
Nombre: SSL/TLS: Weak Key Exchange (KEX) Algorithm(s) Supported (SSH) ID de CVE: N/A (Vulnerabilidad de configuración, sin CVE específico asignado) Descripción: El servidor SSH remoto permite el uso de algoritmos de intercambio de claves (KEX) débiles, como Diffie-Hellman con SHA-1 y grupos de 1024 bits. Esto facilita que un atacante con recursos intercepte y descifre las conexiones individuales.
Fecha de publicación: N/A (No aplica por no tener CVE)
CVSS Score: (5.3)
Acciones para corregir: Deshabilitar los algoritmos KEX débiles en la configuración del servidor SSH y utilizar en su lugar Curva Elíptica Diffie-Hellman (ej. Curve 25519)

Vulnerabilidad 3:
Nombre: SSL/TLS: Weak Host Key Algorithm(s) (SSH)
ID de CVE: N/A (Vulnerabilidad de configuración)
Descripción: El servidor SSH remoto está configurado para permitir algoritmos de clave de host débiles, específicamente el Algoritmo de Firma Digital (DSA/DSS o ssh-dss), el cual es obsoleto y se considera inseguro.
Fecha de publicación: N/A
CVSS Score: (5.3)
Acciones para corregir: Deshabilitar el algoritmo de clave de host débil reportado (ssh-dss) en el archivo de configuración del servicio SSH.

Vulnerabilidad 4:
Nombre: SSL/TLS: FTP Unencrypted Cleartext Login
ID de CVE: N/A (Problema de configuración)
Descripción: El servicio FTP remoto permite inicios de sesión en texto claro a través de conexiones no cifradas, sin forzar el uso del comando 'AUTH TLS'. Esto permite a un atacante interceptar nombres de usuario y contraseñas analizando el tráfico de red. Fecha de publicación: N/A
CVSS Score: (4.8)
Acciones para corregir: Habilitar FTPS en el servidor o forzar obligatoriamente la conexión cifrada requiriendo el comando 'AUTH TLS' antes de permitir la autenticación.

Vulnerabilidad 5:
Nombre: SSL/TLS: Cleartext Transmission of Sensitive Information via HTTP ID de CVE: N/A (Problema de configuración)
Descripción: La aplicación web transmite información confidencial (como nombres de usuario y contraseñas) en texto claro a través de HTTP (ej. en phpMyAdmin y Drupal). Un atacante podría usar un ataque de intermediario (Man-in-the-Middle) para robar estas credenciales.
Fecha de publicación: N/A
CVSS Score: (4.8)
Acciones para corregir: Forzar la transmisión de datos confidenciales a través de una conexión cifrada SSL/TLS (HTTPS). Configurar el servidor para redirigir automáticamente todo el tráfico HTTP a HTTPS antes de mostrar los formularios de inicio de sesión.

Conclusión:
A través de la presente auditoría, se logró evaluar la postura de seguridad de la infraestructura simulada de SEES mediante la herramienta OpenVAS. La detección de debilidades en los protocolos de comunicación (como SSH, FTP y HTTP) y la posterior propuesta de mitigaciones técnicas evidencian la importancia de un monitoreo continuo. Asimismo, la justificación de controles como el cifrado y los sistemas IDS/IPS demuestra que la ciberseguridad debe abordarse desde una perspectiva ética y legal; asegurando que el cumplimiento de normativas

como la Ley 21.663 no solo protege la continuidad operativa de la organización, sino que también garantice el respeto a la privacidad y los derechos de los usuarios finales.